

SÉCURITÉ DES SYSTÈMES

M1 CSIA (S2)

M. MEDEDJEL

2025-2026

COURS 3 : CONTRÔLE D'ACCÈS

OBJECTIFS

L'objectif de ce cours :

- ◆ Expliquer comment le contrôle d'accès s'inscrit dans un contexte plus large qui comprend l'authentification, l'autorisation et l'audit.
- ◆ Définir les catégories des politiques de contrôle d'accès.
- ◆ Décrire le modèle de contrôle d'accès aux fichiers UNIX.
- ◆ Discuter les principaux concepts du contrôle d'accès basé sur les rôles/attributs.

INTRODUCTION

Définition

Deux définitions du contrôle d'accès sont utiles pour comprendre sa portée.

Def. 1 : *NISTIR 7298 (Glossary of Key Information Security Terms, May 2013), defines access control as the process of granting or denying specific requests to:*

- a. Obtain and use information and related information processing services; and*
- b. Enter specific physical facilities.*

INTRODUCTION

Définition

Def. 2 : *RFC 4949, (Internet Security Glossary), defines access control as a process by which use of system resources is regulated according to a security policy and is permitted only by authorized entities (users, programs, processes, or other systems).*

INTRODUCTION

Le contrôle d'accès constitue un **mécanisme fondamental** de la sécurité des systèmes d'information.

Il vise à garantir que seules les entités autorisées puissent accéder aux ressources, conformément aux **règles de sécurité définies**.

INTRODUCTION

Ses objectifs principaux sont :

- ◆ **Empêcher les entités non autorisées** (utilisateurs, processus, systèmes) d'accéder aux ressources ;
- ◆ **Empêcher les entités autorisées d'effectuer des actions non permises** sur les ressources ;
- ◆ **Permettre aux entités autorisées d'accéder aux ressources conformément aux politiques de sécurité.**

INTRODUCTION

Dans ce cours,

- ➔ Nous commencerons par présenter les **concepts fondamentaux** du contrôle d'accès ;
- ➔ Nous analyserons ensuite les **principales techniques et modèles** utilisés pour implémenter les politiques de contrôle d'accès ;
- ➔ Enfin, nous adopterons une **approche globale de la gestion du contrôle d'accès**, fondée sur la gestion des identités, des informations d'identification et des attributs.

PRINCIPES DE CONTRÔLE D'ACCÈS



Au sens plus large, toute la sécurité informatique est concernée par le contrôle d'accès.

Access Control

Le contrôle d'accès met en œuvre une politique de sécurité qui spécifie **qui ou quoi** (ou quelle entité) peut avoir accès à **quelle ressource** spécifique du système, et **quel type d'accès** est autorisé dans chaque cas.

PRINCIPES DE CONTRÔLE D'ACCÈS

Contexte du contrôle d'accès

Dans une perspective plus globale, le contrôle d'accès s'inscrit dans un ensemble de fonctions complémentaires, souvent regroupées sous le modèle **AAA** (***A**uthentication, **A**uthorization, **A**ccounting/**A**udit*).

PRINCIPES DE CONTRÔLE D'ACCÈS

Contexte du contrôle d'accès

1. **Authentication** : (@Cours 2)

Processus de vérification de l'identité d'une entité (utilisateur, processus ou système) à partir de ses **informations d'identification** (identifiant, mot de passe, certificat, jeton, biométrie, etc.).

Elle répond à la question : **Qui êtes-vous ?**

PRINCIPES DE CONTRÔLE D'ACCÈS

Contexte du contrôle d'accès

2. Autorisation :

Processus d'attribution ou de refus de droits d'accès à une entité authentifiée, conformément à la politique de sécurité en vigueur. Elle détermine **quelles actions** une entité est autorisée à effectuer sur quelles ressources.

Elle répond à la question : **Que pouvez-vous faire ?**

PRINCIPES DE CONTRÔLE D'ACCÈS

Contexte du contrôle d'accès

3. Audit :

Mécanisme d'enregistrement, de surveillance et d'examen des activités du système afin de :

- Évaluer l'efficacité des contrôles de sécurité ;
- Vérifier la conformité aux politiques et procédures établies ;
- Détecter d'éventuelles violations ou anomalies ;
- Recommander des améliorations en matière de politiques et de mécanismes de contrôle.

L'audit répond à la question : **Que s'est-il passé ?**

PRINCIPES DE CONTRÔLE D'ACCÈS

Contexte du contrôle d'accès

La figure 1 montre un exemple d'un contexte plus large du contrôle d'accès.

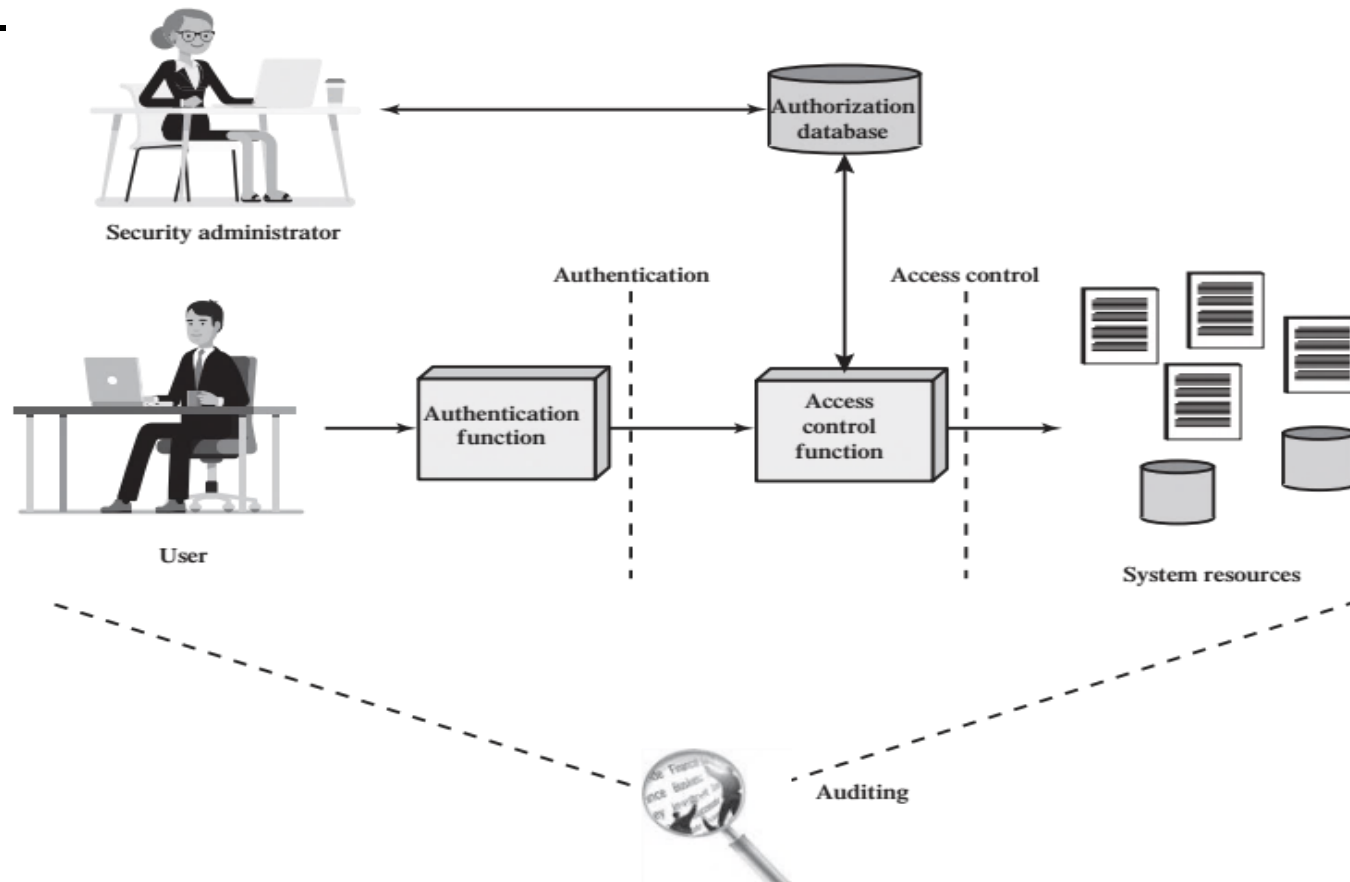


Figure 1. Relation entre le contrôle d'accès et les autres fonctions de sécurité.

PRINCIPES DE CONTRÔLE D'ACCÈS

Contexte du contrôle d'accès

Un **mécanisme de contrôle d'accès** assure la **médiation** entre une entité demandeuse (utilisateur, processus ou service) et les ressources du système (Applications, SE, Pare-feux, Routeurs, Fichiers et BDD).



Généralement, la fonction d'authentification détermine si l'utilisateur est autorisé à accéder au système. Ensuite, la fonction de contrôle d'accès détermine si l'accès spécifique demandé par cet utilisateur est autorisé.

PRINCIPES DE CONTRÔLE D'ACCÈS

Exemple de fonctionnement du contrôle d'accès

À titre d'illustration :

- Un **administrateur de sécurité** définit et maintient une **base de données d'autorisations** (ou référentiel d'accès) spécifiant :
 - quels utilisateurs ou rôles,
 - peuvent accéder à quelles ressources,
 - avec quels types de permissions (lecture, écriture, exécution, etc.).
- La **fonction de contrôle d'accès** interroge ce référentiel afin de déterminer si la requête d'accès doit être **autorisée ou refusée**, conformément à la politique de sécurité.
- Une **fonction d'audit** enregistre et surveille les tentatives d'accès ainsi que les actions effectuées sur les ressources du système.

PRINCIPES DE CONTRÔLE D'ACCÈS

Types de contrôle d'accès

Un mécanisme de contrôle d'accès peut être :

➤ **Physique** :

Il repose sur des **dispositifs matériels et des barrières physiques** destinés à empêcher tout accès non autorisé aux sites, aux locaux et aux équipements sensibles.

Il permet de déterminer :

- **Qui** est autorisé à entrer ou sortir ;
- **Où** l'accès est permis (zones, salles, périmètres spécifiques) ;
- **Quand** l'accès est autorisé (plages horaires, restrictions temporelles).

Exemples : badges d'accès, cartes magnétiques, serrures électroniques, biométrie, tourniquets, ...

PRINCIPES DE CONTRÔLE D'ACCÈS

Types de contrôle d'accès

➤ **Logique** :

Le **contrôle d'accès logique** repose sur des mécanismes matériels et logiciels permettant de réguler l'accès aux ressources numériques.

Il met en œuvre :

- ✓ **Identification** : déclaration d'identité
- ✓ **Authentification** : vérification de l'identité
- ✓ **Autorisation** : attribution des droits d'accès

Il s'applique aux

- systèmes,
- applications,
- bases de données et
- équipements réseau.

PRINCIPES DE CONTRÔLE D'ACCÈS

Types de contrôle d'accès

➤ Administratif :

Le **contrôle d'accès administratif** repose sur des **procédures et politiques organisationnelles** visant à prévenir les accès non autorisés.

Il se concentre sur les **pratiques personnelles et professionnelles**, telles que :

- la gestion des comptes et des rôles,
- la sensibilisation et formation des utilisateurs,
- les procédures de sécurité et conformité.

PRINCIPES DE CONTRÔLE D'ACCÈS

Politiques de contrôle d'accès

Une politique de contrôle d'accès peut être implémentée dans une base de données d'autorisation pour automatiser les décisions d'accès. Notamment, définir quels types d'accès sont autorisés, dans quelles circonstances et par qui.

PRINCIPES DE CONTRÔLE D'ACCÈS

Politiques de contrôle d'accès

Les politiques de contrôle d'accès sont classées généralement dans les catégories suivantes :

❑ **Contrôle d'accès discrétionnaire (DAC) :**

Le propriétaire d'une ressource décide qui peut y accéder et avec quels droits.

Exemple : sous Unix/Linux

Une entité a le droit de changer les permissions d'accès aux objets qu'elle contrôle (**chmod**).

PRINCIPES DE CONTRÔLE D'ACCÈS

Politiques de contrôle d'accès

❑ Contrôle d'accès obligatoire (MAC) :

L'accès est basé sur des règles centralisées définies par l'organisation, souvent selon des **niveaux de sécurité**.

PRINCIPES DE CONTRÔLE D'ACCÈS

Politiques de contrôle d'accès

❑ Contrôle d'accès basé sur les rôles (RBAC) :

Les droits d'accès sont attribués en fonction des **rôles** des utilisateurs dans l'organisation.

PRINCIPES DE CONTRÔLE D'ACCÈS

Politiques de contrôle d'accès

❑ Contrôle d'accès basé sur les attributs (ABAC) :

Contrôle l'accès en fonction des **attributs** de l'utilisateur, des ressources à lesquelles il doit accéder et de l'environnement.

PRINCIPES DE CONTRÔLE D'ACCÈS

Remarque :

Ces quatre politiques ne s'excluent pas mutuellement.

Un mécanisme de contrôle d'accès peut utiliser deux, voire trois de ces politiques pour couvrir différentes catégories de système.

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Sujets, Objets et Droits d'accès

Les éléments fondamentaux du contrôle d'accès sont :

- **Le sujet**
- **L'objet**
- **Le droit d'accès**

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Sujets, Objets et Droits d'accès

➤ **Sujet**

- Un **sujet** est une entité active capable de demander l'accès à une ressource.
- Dans les systèmes informatiques, le sujet correspond généralement à un **processus**.
- En effet, un utilisateur ou une application n'accède pas directement à une ressource : l'accès s'effectue via un processus qui agit en son nom.
- Ce processus hérite des **attributs de sécurité** de l'utilisateur (identité, rôles, privilèges, droits d'accès).
- Un sujet est responsable des actions qu'il initie sur les objets.

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Sujets, Objets et Droits d'accès

➤ **Sujet**

Les systèmes de contrôle d'accès de base distinguent généralement trois classes de sujets, avec des droits d'accès différents :

a. Propriétaire (*Owner*) :

C'est l'utilisateur ayant créé la ressource (fichier, répertoire, etc.).

Il dispose des **droits les plus étendus** sur cette ressource, notamment :

- Lecture,
- Ecriture,
- Modification,
- Suppression,
- Gestion des permissions

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Sujets, Objets et Droits d'accès

b. Groupe (*Group*) :

Un **groupe** est un ensemble d'utilisateurs partageant des permissions communes sur une ressource.

En complément des droits du propriétaire, des **permissions spécifiques** peuvent être attribuées à un groupe par le propriétaire ou par l'administrateur, afin d'accorder un **accès contrôlé** aux ressources.

Un utilisateur peut appartenir à **plusieurs groupes**, ce qui entraîne l'agrégation de ses droits selon les règles du système.

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Sujets, Objets et Droits d'accès

c. *Autres (Others/Public)* :

Cette catégorie regroupe tous les utilisateurs qui ne sont **ni le propriétaire**, ni membres du **groupe associé** à la ressource.

Les droits attribués à cette classe sont généralement **les plus restrictifs**, afin de réduire les risques de compromission et d'accès non autorisé.

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Sujets, Objets et Droits d'accès

➤ Objet

Un **objet** est une ressource dont l'accès est contrôlé.

Il s'agit généralement d'une **entité passive** destinée à contenir, stocker ou recevoir des informations.

Exemple :

- Enregistrements
- Fichiers
- Répertoires et arborescences
- Messages

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Sujets, Objets et Droits d'accès

Remarque:

Dans certains systèmes, le contrôle d'accès peut également s'appliquer à des ressources plus fines ou techniques, telles que :

- Bits, octets, mots mémoire
- Ports de communication
- Horloges système
- Nœuds réseau

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Sujets, Objets et Droits d'accès

➤ Droit d'accès

Un **droit d'accès** décrit la manière dont un sujet peut accéder à un objet.

Les droits les plus courants sont :

- **Lecture (Read)**

Permet de consulter les informations d'une ressource (fichier, enregistrement, champ, etc.). Inclut généralement la possibilité de copier ou d'imprimer le contenu.

- **Écriture (Write)**

Permet d'ajouter, modifier ou supprimer des données dans une ressource. Inclut généralement le droit de lecture.

- **Exécution (Execute)**

Permet de lancer un programme ou un fichier exécutable.

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Sujets, Objets et Droits d'accès

- **Création (Create)**

Permet de créer de nouvelles ressources (fichiers, enregistrements, champs, répertoires).

- **Recherche / Parcours (Search / List)**

Permet de consulter le contenu d'un répertoire (liste des fichiers) ou d'effectuer des opérations de recherche au sein d'une structure.

- **Suppression (Delete)**

Permet de supprimer une ressource du système (fichier, enregistrement, etc.).

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Exemple : SE

Sujets :

- ?
- ...
- ...

Objets :

- ?
- ...
- ...

Droits d'accès :

- ?
- ...
- ...

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Exemple : SE

Sujets :

- Processus,
- Programmes,
- Services système

Objets :

- Fichier
- Dossier
- Espace mémoire
- Périphériques

Droits d'accès :

- Lecture
- Écriture
- Exécution
- ...

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Modèle formel du contrôle d'accès

Le contrôle d'accès peut être représenté par la relation suivante :

$$\textit{Sujet} \xrightarrow{\textit{Droit}} \textit{Objet}$$

Ou de manière fonctionnelle :

$$\textit{Autorisation} = f(\textit{Sujet}, \textit{Objet}, \textit{Action})$$

ENTITÉS D'UN SYSTÈME DE CONTRÔLE D'ACCÈS

Modèle formel du contrôle d'accès

Exemple concret (SE)

Processus (UID=1001) $\xrightarrow{\text{Lecture}}$ *Fichier* /etc/config

Le système vérifie alors la politique d'accès avant d'autoriser ou de refuser l'opération.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

A suivre...

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Comme indiqué précédemment, le **contrôle d'accès discrétionnaire (DAC)** est un modèle dans lequel une entité disposant de droits d'accès peut **accorder ou déléguer** ces droits à d'autres entités pour certaines ressources.

Dans les systèmes informatiques, tels que les **SE** et les **SGBD**, le DAC est généralement implémenté à l'aide d'une **matrice de contrôle d'accès** (*access matrix*).

Le concept de matrice de contrôle d'accès a été introduit par **Butler Lampson** en 1971.

[LAMP71] Lampson, Butler W. (1971). "Protection". *Proceedings of the 5th Princeton Conference on Information Sciences and Systems*. p. 437.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Matrice de contrôle d'accès

La **figure 2.a** présente un exemple simplifié de **matrice de contrôle d'accès**, illustrant l'attribution des droits d'accès des utilisateurs aux ressources du système.

		OBJECTS			
		File 1	File 2	File 3	File 4
SUBJECTS	User A	Own Read Write		Own Read Write	
	User B	Read	Own Read Write	Write	Read
	User C	Read Write	Read		Own Read Write

(a) Access matrix

Figure 2. Exemple de matrice de contrôle d'accès

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Matrice de contrôle d'accès — Implémentation

En pratique, la **matrice de contrôle d'accès** est implémentée par décomposition :

- **Par colonnes** → **Listes de contrôle d'accès (ACL)** (*Figure 2.b*)
- **Par lignes** → **Listes de capacités (CL)** (*Figure 2.c*)

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Liste de contrôle d'accès (ACL)

Une **liste de contrôle d'accès (ACL)** est associée à chaque **objet** et définit :

- les **sujets autorisés** (utilisateurs et groupes),
- les **droits d'accès** correspondants.

Une ACL peut inclure une **entrée par défaut (publique)**, attribuant des droits minimaux aux sujets non explicitement listés (par exemple : lecture seule).

Les entrées d'une ACL peuvent concerner :

- des **utilisateurs individuels**,
- des **groupes d'utilisateurs**.

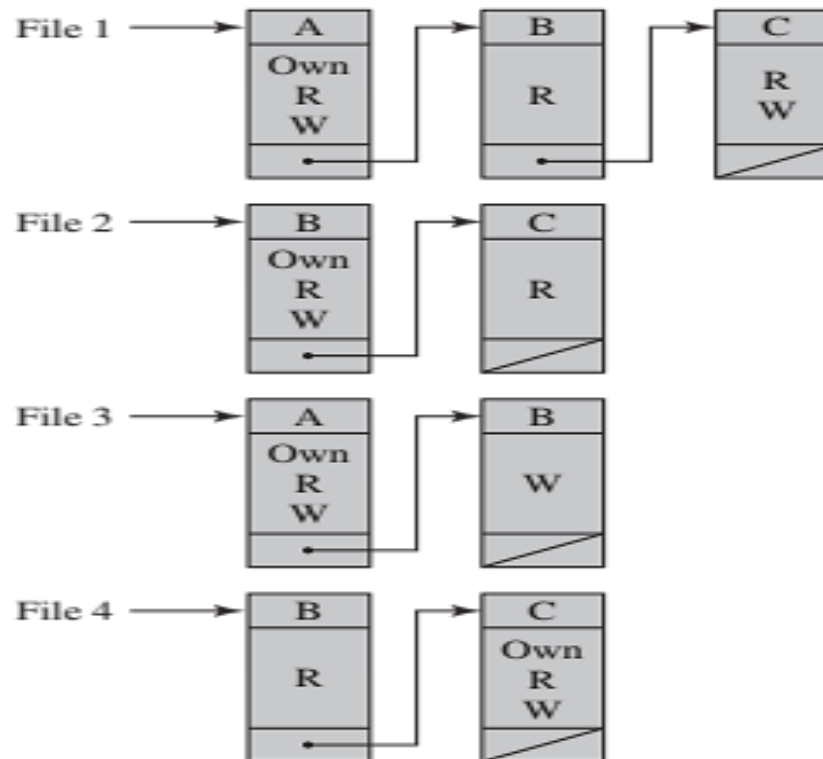
Avantage : efficace pour déterminer quels sujets ont quels droits sur une ressource donnée.

Limite : peu adaptée pour identifier l'ensemble des droits d'un utilisateur sur toutes les ressources.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

➤ Exemple d'ACL

La **figure 2.b** illustre un exemple d'**ACL** appliquée aux fichiers issus de la matrice de contrôle d'accès.



(b) Access control lists for files of part (a)

Figure 2. Exemple d'ACL

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Liste de capacités (CL)

Une **liste de capacités (Capability List)** est associée à chaque **sujet** et définit les **objets** auxquels il peut accéder ainsi que les **droits correspondants**.

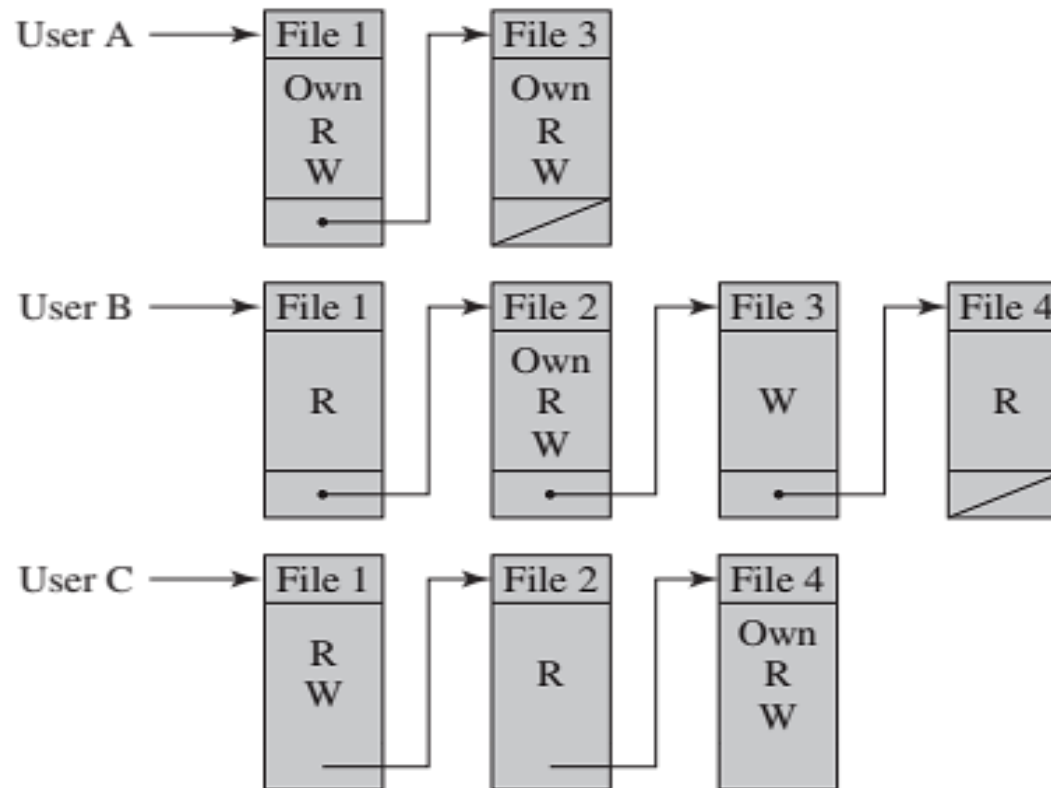
Avantage : efficace pour déterminer l'ensemble des droits d'un sujet.

Limite : plus complexe à gérer lors de la révocation des droits.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Liste de capacités (CL)

La **figure 2.c** illustre un exemple d'une **CL** des fichiers de la matrice d'accès.



(c) Capability lists for files of part (a)

Figure 2. Exemple de CL.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Domaines de protection

- Dans le modèle de matrice d'accès présenté jusqu'ici, un ensemble de droits est directement associé à chaque utilisateur.
- Une approche plus générale et plus flexible, proposée dans [LAMP71], consiste à associer les droits non pas aux utilisateurs eux-mêmes, mais à des domaines de protection.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Domaines de protection

Un domaine de protection est un ensemble de droits d'accès attribués à un utilisateur ou à un processus.

Un sujet peut :

- opérer dans **un ou plusieurs domaines**,
- **changer de domaine**, ce qui modifie dynamiquement ses privilèges.

Les domaines sont utilisés pour :

- appliquer le **principe du moindre privilège**,
- isoler les fonctions sensibles (ex. noyau / utilisateur).

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Contrôle d'accès aux fichiers UNIX — ACL minimale

- Chaque utilisateur possède un identifiant unique, appelé **UID** (User ID).
- Un utilisateur appartient à un groupe principal et éventuellement à d'autres groupes, chacun identifié par un **GID** (Group ID).
- Lorsqu'un fichier est créé, il est marqué comme appartenant à un utilisateur, via son UID.
- Le fichier appartient aussi à un groupe, identifié par un GID, qui est en général soit le groupe principal du créateur, soit le groupe du répertoire parent.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Contrôle d'accès aux fichiers UNIX — ACL minimale

- Chaque fichier est associé à un ensemble de permissions.
- **9 bits** indiquent les droits de lecture, d'écriture et d'exécution pour :
 - le propriétaire du fichier,
 - les membres du groupe du fichier,
 - tous les autres utilisateurs.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Contrôle d'accès aux fichiers UNIX — ACL minimale

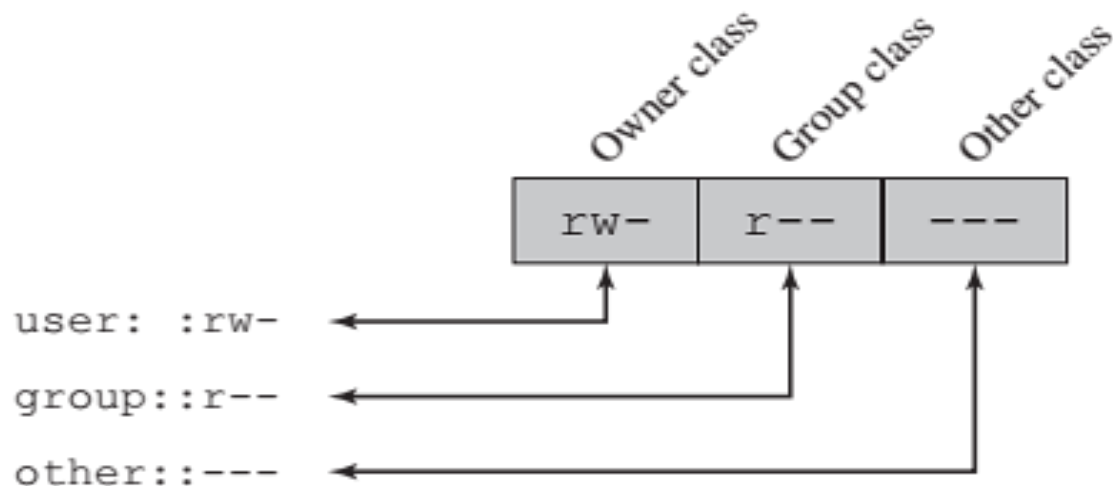
- D'autres bits contrôlent des comportements **spéciaux** pour les fichiers ou répertoires, notamment :
 - les bits **SetUID** et **SetGID** ;
 - le **sticky bit**, qui, sur un répertoire, permet qu'un fichier ne puisse être supprimé que par son propriétaire ou par le propriétaire du répertoire.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Contrôle d'accès aux fichiers UNIX (ACL minimale)

La **figure 3.a** montre un exemple dans lequel:

- le propriétaire du fichier a un accès en lecture et en écriture ;
- les membres du groupe du fichier ont un accès en lecture ;
- les autres utilisateurs (extérieurs au groupe) n'ont aucun droit d'accès.



(a) Traditional UNIX approach (minimal access control list)

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Remarque sur les permissions de répertoire

i. Pour un répertoire :

- bit de lecture : permet de lister son contenu ;
- bit d'écriture : permet de créer, renommer ou supprimer des fichiers dans ce répertoire ;
- bit d'exécution : permet d'y accéder (y « descendre ») et d'y rechercher un nom de fichier.

ii. Les permissions d'un répertoire sont indépendantes de celles des fichiers qu'il contient.

- Avoir le droit d'écriture sur le répertoire ne donne pas le droit de modifier le contenu d'un fichier (cela dépend des droits du fichier lui-même).
- En revanche, l'utilisateur pourra renommer ou supprimer ce fichier s'il a les droits adéquats sur le répertoire.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Contrôle d'accès aux fichiers UNIX — ACL étendue

Les **ACL étendues** permettent d'ajouter des entrées spécifiques pour :

- des **utilisateurs supplémentaires**,
- des **groupes supplémentaires**.

Elles offrent :

- une granularité fine des permissions,
- une meilleure adaptation aux environnements multi-utilisateurs complexes.

Elles complètent le modèle UNIX classique sans le remplacer.

De nombreux systèmes UNIX modernes les supportent, comme FreeBSD, OpenBSD, Linux ou Solaris.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Contrôle d'accès aux fichiers UNIX — ACL étendue

Dans les ACLs étendues :

1. Les classes « propriétaire », « groupe » et « autres » dans les 9 bits classiques gardent la même signification que dans l'ACL minimale.
2. L'entrée de **classe de groupe** indique les permissions du groupe propriétaire du fichier.
3. Le **masque** définit les permissions maximales possibles pour tous les utilisateurs et groupes nommés (sauf le propriétaire).
4. Des **utilisateurs nommés** et **groupes nommés** supplémentaires peuvent être associés au fichier, chacun avec 3 bits de droits ; leurs permissions effectives sont limitées par le masque.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Contrôle d'accès aux fichiers UNIX — ACL étendue

La Figure 3.b illustre un exemple d'une ACL étendue :

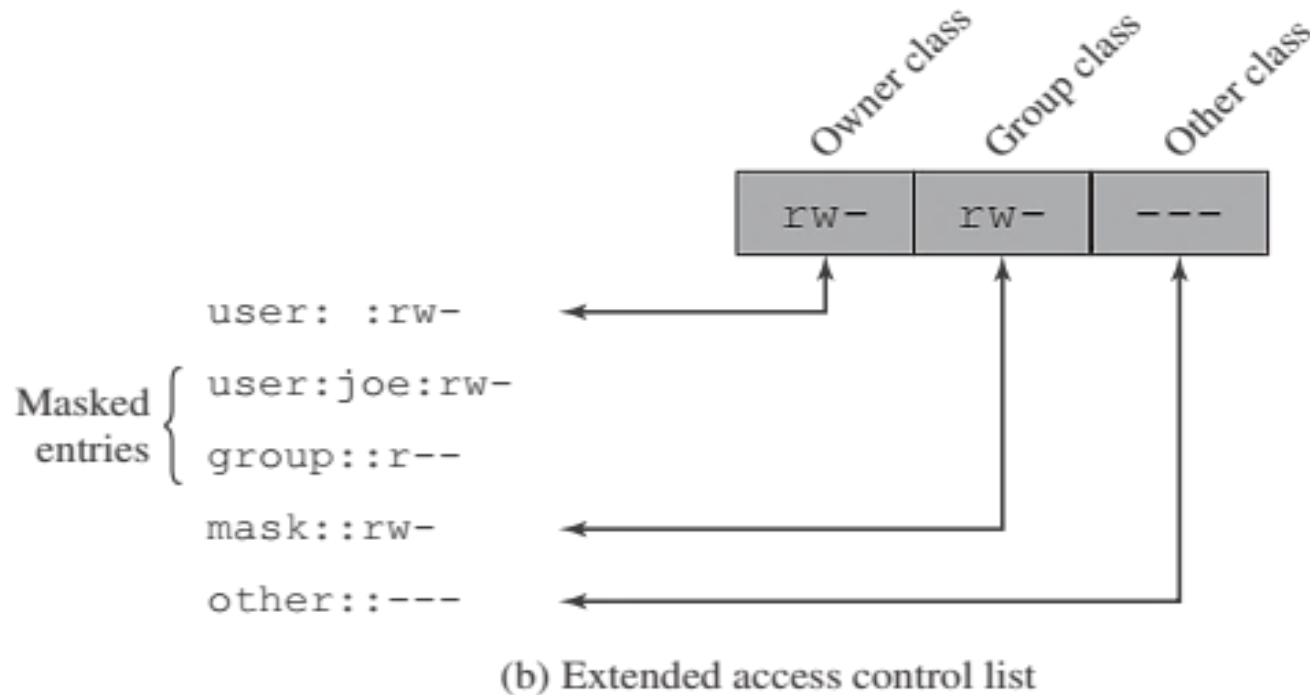


Figure 3. Contrôle d'accès aux fichiers UNIX

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Exemple d'ACL étendue

Tableau 1 : Masquage des permissions

Entry type	Text form	Permissions
Named user	user:fred:r-x	r-x
Mask	mask::rw-	rw-
Effective permissions		r--

P.s. Les permissions du propriétaire sont toujours effectives et ne sont jamais masquées.

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Exemple: Afficher les droits d'un fichier avec une **ACL étendue** sous Linux.

1) Afficher les permissions classiques (ACL minimale)

- La commande classique montre si une ACL est présente :

ls -l fichier

- Sil y a un **+** à la fin des permissions, ça indique une **ACL étendue** :

-rw-r--r--+ 1 user groupe 4096 mar 10 14:05 fichier

2) Afficher les ACL étendues

- affichage plus détaillé : **getfacl**
- un aperçu rapide : **ls -v** (ou **ls -Z**)

CONTRÔLE D'ACCÈS DISCRÉTIONNAIRE

Exemple: Afficher les droits d'un fichier avec une **ACL étendue** sous Linux.

2) Afficher les ACL étendues avec **getfacl**

getfacl fichier.txt

Exemple de résultat :

```
# file: fichier.txt
# owner: user
# group: groupe
user::rw-          # Permissions du propriétaire
user:paul:rw-       # ACL spécifique pour l'utilisateur paul
group::r--          # Permissions du groupe de base
group:compta:r--    # ACL spécifique pour le groupe compta
mask::rw-          # Masque limitant les droits effectifs
other::r--          # Droits pour tous les autres
```

CONTRÔLE D'ACCÈS BASÉ SUR LES RÔLES

Contrôle d'accès basé sur les rôles (RBAC)

- Le **RBAC (Role-Based Access Control)** repose sur l'attribution de permissions aux **rôles**, et non directement aux utilisateurs.
- Les utilisateurs se voient assigner un ou plusieurs rôles selon leurs **fonctions organisationnelles**.

CONTRÔLE D'ACCÈS BASÉ SUR LES RÔLES

Contrôle d'accès basé sur les rôles (RBAC)

- La relation entre les utilisateurs et les rôles est **plusieurs-à-plusieurs**, tout comme la relation entre les rôles et les ressources (objets du système).
- L'affectation d'un utilisateur à un ou plusieurs rôles peut être :
 - **dynamique**, si ses rôles changent selon le contexte ou l'environnement ;
 - **statique**, quand les rôles du système évoluent peu, avec seulement quelques ajouts ou suppressions.
- Chaque rôle regroupe des droits d'accès bien définis sur une ou plusieurs ressources.

CONTRÔLE D'ACCÈS BASÉ SUR LES RÔLES

Contrôle d'accès basé sur les rôles (RBAC)

La figure 4 illustre un exemple de ce modèle.

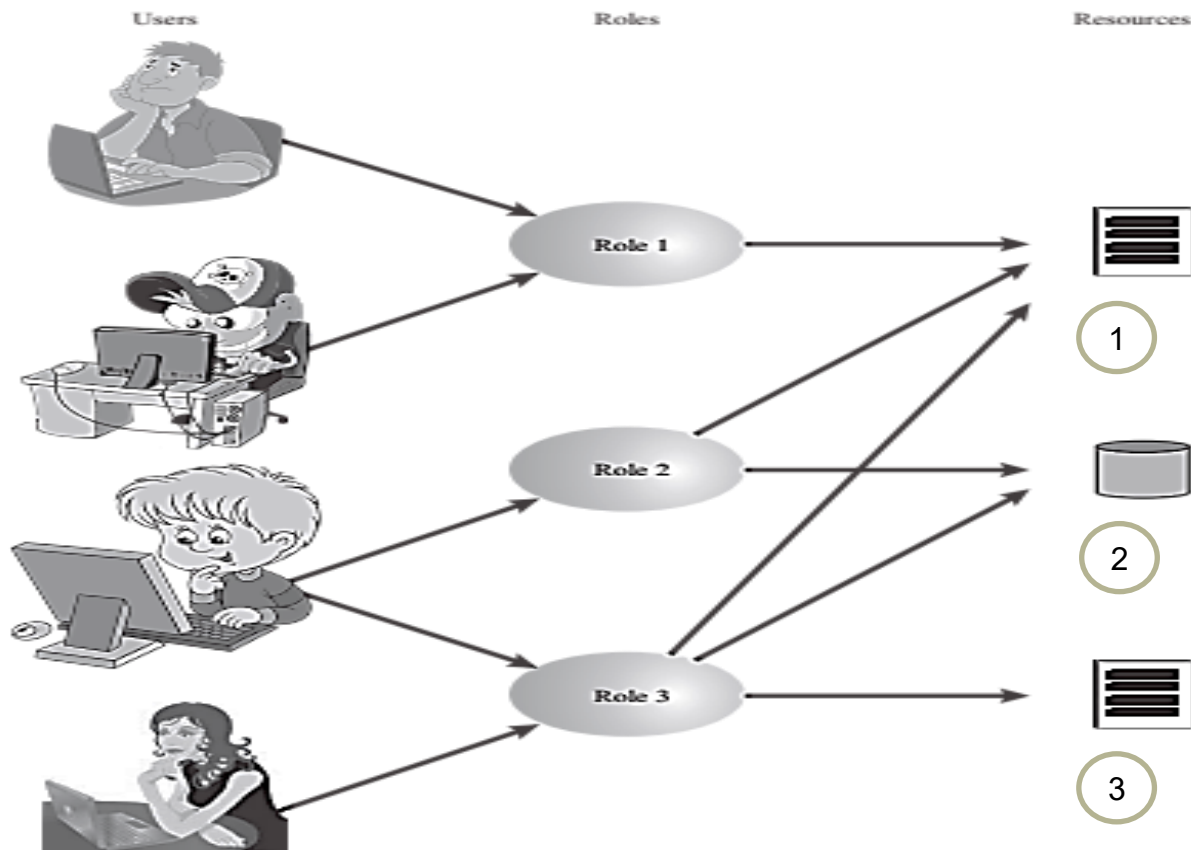


Figure 4. Utilisateurs, rôles et ressources.

CONTRÔLE D'ACCÈS BASÉ SUR LES RÔLES

Contrôle d'accès basé sur les rôles (RBAC)

- On peut représenter simplement un système RBAC avec une matrice d'accès, comme sur la figure 5(a)/(b).
- Dans cette matrice, les rôles tiennent la place intermédiaire entre les utilisateurs et les ressources, ce qui permet de visualiser clairement quels rôles donnent accès à quels objets.

CONTRÔLE D'ACCÈS BASÉ SUR LES RÔLES

Contrôle d'accès basé sur les rôles (RBAC)

	R_1	R_2	$\cdot \cdot \cdot$	R_n
U_1	✕			
U_2	✕			
U_3		✕		✕
U_4				✕
U_5				✕
U_6				✕
$\vdots$				
U_m	✕			

(a)

Figure 5. Matrice d'accès de RBAC.

CONTRÔLE D'ACCÈS BASÉ SUR LES RÔLES

Contrôle d'accès basé sur les rôles (RBAC)

		OBJECTS								
		R_1	R_2	R_n	F_1	F_2	P_1	P_2	D_1	D_2
ROLES	R_1	control	owner	owner control	read $\wedge$	read owner	wakeup	wakeup	seek	owner
	R_2		control		write	execute			owner	seek $\wedge$
	•									
	•									
	R_n			control		write	stop			

(b)

Figure 5. Matrice d'accès de RBAC.

CONTRÔLE D'ACCÈS BASÉ SUR LES RÔLES

Exemple de scénario avec RBAC

Soit une entreprise avec un serveur de fichiers :

Rôle	Permissions	Utilisateurs
Admin	Lire, écrire, modifier, supprimer	Mohamed ou Karim
Développeur	Lire, écrire, modifier	Youcef , Ismail
Lecteur	Lire	Ali, Omar

CONTRÔLE D'ACCÈS BASÉ SUR LES RÔLES

Avantages de RBAC

- ✓ **Simplicité d'administration** : gère les droits par **rôle** et non par utilisateur.
- ✓ **Évolutivité** : ajoute de nouveaux utilisateurs sans refaire la configuration.
- ✓ **Sécurité renforcée** : les utilisateurs obtiennent uniquement les droits nécessaires à leur rôle (principe du **moindre privilège**).
- ✓ **Audit plus clair** : Il est plus facile de savoir qui a accès à quoi et pourquoi.

CONTRÔLE D'ACCÈS BASÉ SUR LES ATTRIBUTS

Contrôle d'accès basé sur les attributs (ABAC)

- Le **ABAC (Attribute-Based Access Control)** fonde la décision d'accès sur des **attributs** relatifs :
 - au sujet (rôle, âge, service, niveau),
 - à l'objet (type, classification),
 - à l'environnement (heure, localisation, contexte).
- Il permet des **politiques dynamiques et contextuelles**, adaptées aux environnements distribués et modernes.
- Ce modèle est largement utilisé dans les **services Web**, notamment via le langage XACML (eXtensible Access Control Markup Language), ainsi que dans de nombreux services de Cloud computing, qui s'appuient fortement sur ce type de politique d'accès.

CONTRÔLE D'ACCÈS BASÉ SUR LES ATTRIBUTS

Contrôle d'accès basé sur les attributs (ABAC)

❑ Types d'attributs :

- **Attributs de sujet** : chaque sujet a des attributs associés qui définissent son identité et ses caractéristiques. Ces attributs peuvent inclure l'identifiant du sujet, le nom, l'organisation, le titre du poste, etc.

Par exp. Le rôle d'un sujet peut également être considéré comme un attribut.

CONTRÔLE D'ACCÈS BASÉ SUR LES ATTRIBUTS

Contrôle d'accès basé sur les attributs (ABAC)

❑ Types d'attributs :

- **Attributs d'objet** : les attributs d'objet peuvent être exploités pour prendre des décisions de contrôle d'accès.

Par exp. Un document Word peut avoir des attributs tels que le titre, le sujet, la date et l'auteur. Les attributs d'objet peuvent souvent être extraits des métadonnées de l'objet.

CONTRÔLE D'ACCÈS BASÉ SUR LES ATTRIBUTS

Contrôle d'accès basé sur les attributs (ABAC)

❑ Types d'attributs :

- **Attributs d'environnement** : ces attributs décrivent l'environnement ou le contexte opérationnel, technique et même situationnel dans lequel l'accès à l'information se produit.

Par exp. les attributs, tels que la date et l'heure actuelles ou le niveau de sécurité du réseau, ne sont pas associés à un sujet particulier ou à une ressource, mais peuvent néanmoins être pertinents pour appliquer une politique de contrôle d'accès.

CONTRÔLE D'ACCÈS BASÉ SUR LES ATTRIBUTS

Architecture logique d'ABAC

La figure ci-dessous illustre dans une architecture logique les composants essentiels d'un système ABAC.

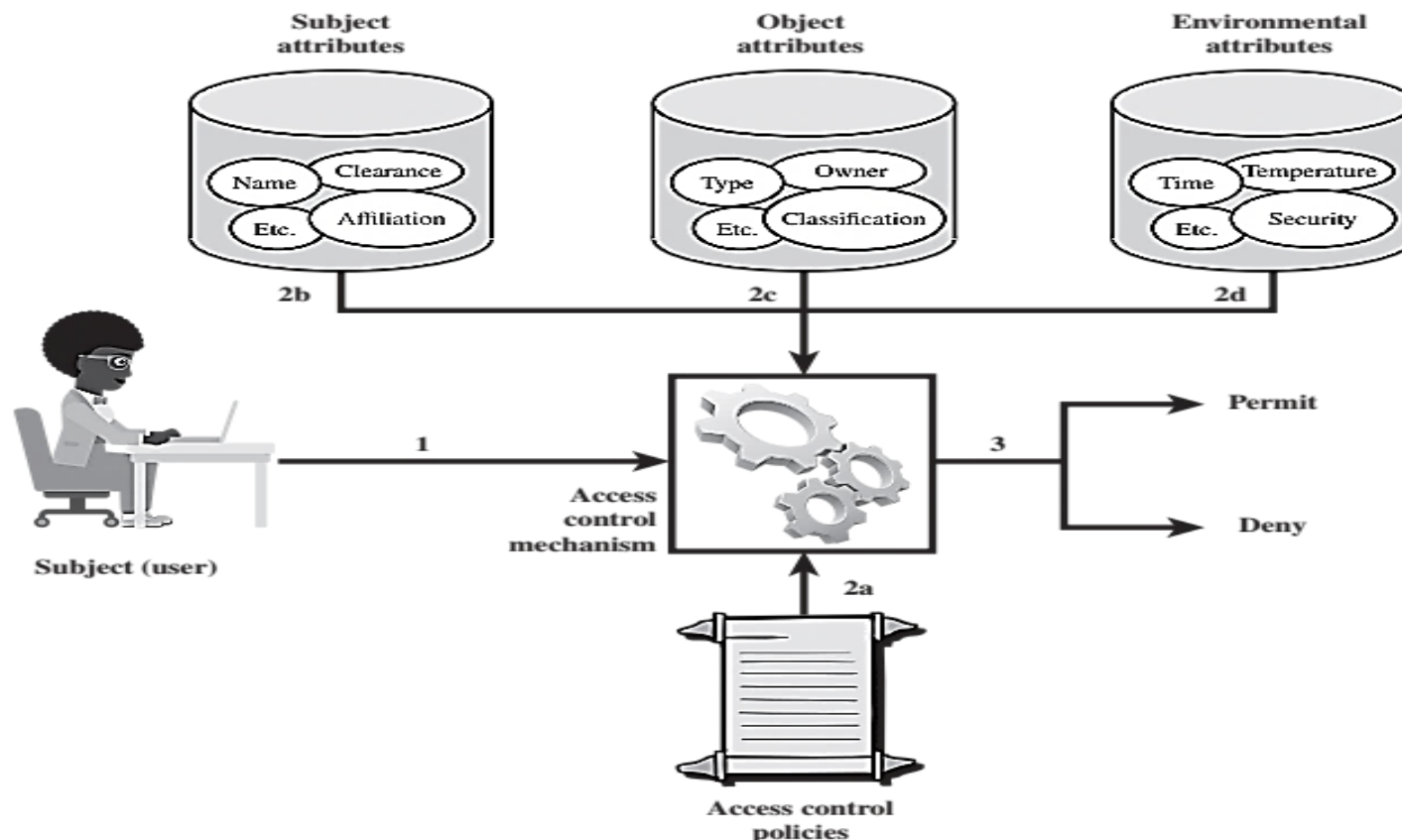


Figure 6. Scénario d'ABAC

CONTRÔLE D'ACCÈS BASÉ SUR LES ATTRIBUTS

Architecture logique d'ABAC

Selon cette architecture, un accès par un sujet à un objet se déroule selon les étapes suivantes :

1. Un sujet demande l'accès à un objet. Cette demande est acheminée vers un mécanisme de contrôle d'accès.
2. Le mécanisme de contrôle d'accès est régi par un ensemble de règles (2a) qui sont définies par une politique de contrôle d'accès préconfigurée. Sur la base de ces règles, le mécanisme de contrôle d'accès évalue les attributs du sujet (2b), de l'objet (2c) et des conditions environnementales actuelles (2d) pour déterminer l'autorisation.
3. Le mécanisme de contrôle d'accès accorde au sujet l'accès à l'objet si l'accès est autorisé, sinon il refuse l'accès.

CONTRÔLE D'ACCÈS BASÉ SUR LES ATTRIBUTS

Exemple de scénario avec ABAC

Soit une entreprise avec un serveur de fichiers sensibles:

Utilisateurs	Rôle	Dpt	Ressource	Action autorisée
Mohamed	Manager	Finance	Rapport finances	Lire, modifier
Ismail	Développeur	IT	Code source	Lire, modifier
Yucef	RH	Ressources humaines	Dossier paie	Lire
Karim	Stagiaire	IT	Code source	Lire

Politique d'accès ABAC associée :

- **Manager** du service **Finance** peut lire et modifier le **Rapport finances**.
- **Développeur** peut modifier le **Code source**.
- **RH** peut lire **Dossier paie**, mais pas modifier.
- **Stagiaire** a accès en lecture seule au **Code source**
- **Heures autorisées** : accès modification entre **8h et 16h**.

CONTRÔLE D'ACCÈS BASÉ SUR LES ATTRIBUTS

ABAC vs Autres politiques

- L'approche ABAC est **très puissante et flexible**, car elle permet d'exprimer des règles d'accès fines basées sur de nombreux attributs.
- En contrepartie, sa conception et sa mise en œuvre sont **plus complexes**, et peuvent avoir un impact plus important sur les performances que les modèles de contrôle d'accès plus simples (comme DAC ou RBAC).
- L'autorité du système doit donc arbitrer entre cette flexibilité accrue et le surcoût de complexité et de performance.

CONTRÔLE D'ACCÈS OBLIGATOIRE

Contrôle d'accès obligatoire (MAC)

Le **MAC (Mandatory Access Control)** est un modèle dans lequel les règles d'accès sont **imposées par une autorité centrale** et **ne peuvent pas être modifiées par les utilisateurs**, même propriétaires des ressources.

Les décisions d'accès reposent sur :

- des **étiquettes de sécurité** associées aux sujets (ex. niveau d'habilitation),
- des **classifications** associées aux objets (ex. niveau de sensibilité).

L'accès est autorisé uniquement si les règles de sécurité globales sont respectées.

CONTRÔLE D'ACCÈS OBLIGATOIRE

Contrôle d'accès obligatoire (MAC)

Caractéristiques clés :

- ✓ Forte centralisation des politiques
- ✓ Application stricte et non contournable
- ✓ Protection élevée contre les fuites d'information

Limites :

- Faible flexibilité
- Administration plus complexe

CONTRÔLE D'ACCÈS OBLIGATOIRE

Comparaison des modèles

Modèle	Principe	Flexibilité	Sécurité	Cas d'usage typiques
DAC	Le propriétaire gère les droits	Élevée	Moyenne	Systèmes généraux, SE
MAC	Règles imposées par l'autorité	Faible	Très élevée	Militaire, gouvernement
RBAC	Droits basés sur les rôles	Moyenne	Élevée	Entreprises, SI
ABAC	Décisions basées sur attributs	Très élevée	Élevée	Cloud, IoT, systèmes dynamiques

**MERCI POUR VOTRE
ATTENTION.**